



Cybersecurity Governance Guide for Regulated Organizations

Financial Industry Regulatory Authority (FINRA)

Technical controls, regulatory frameworks, and continuous monitoring for cybersecurity governance under FINRA requirements.

1. FINRA Cybersecurity Regulatory Landscape

FINRA cybersecurity obligations flow through multiple rules and guidance documents:

- FINRA Rule 4370 (Business Continuity): Requires written BCP covering cybersecurity incidents, data recovery, and alternative communications. Must be tested annually.
- FINRA Rule 3110 (Supervision): Cybersecurity controls are supervised activities. Written supervisory procedures must address cybersecurity.
- FINRA Cybersecurity Report (2015, updated): Establishes baseline expectations for governance, risk assessment, technical controls, incident response, and vendor management.
- Regulatory Notice 22-18: FINRA cybersecurity examination priorities including phishing, ransomware, account takeover, and vendor risk.
- FINRA Sweep Letters: FINRA regularly issues targeted cybersecurity sweeps. Recent sweeps have focused on remote access security, cloud security, and third-party risk.

2. Technical Controls Under FINRA

FINRA cybersecurity framework emphasizes practicable controls proportionate to firm size and risk:

- ✓ Multi-factor authentication on all remote access, email, financial systems, and admin accounts. Explicitly cited in FINRA exam findings.
- ✓ EDR/XDR with 24/7 monitoring. FINRA has cited lack of endpoint detection as a deficiency in multiple exam cycles.
- ✓ Email security: advanced threat protection, DMARC, DKIM, SPF, and anti-phishing controls. Business email compromise is FINRA top cited attack vector.
- ✓ Network segmentation isolating order management, trading, and customer account systems.
- ✓ Patch management with documented SLAs and compliance reporting.
- ✓ Data loss prevention for systems handling customer PII and financial data.

3. Incident Response Under FINRA

FINRA incident response obligations require documented, tested procedures:

- Written Incident Response Plan: Must address detection, triage, containment, notification, recovery, and post-incident review. Must be integrated with Rule 4370 BCP.

- **Notification Obligations:** Prompt notification to FINRA for incidents involving customer harm, regulatory reporting failures, or operational disruption.
- **Customer Notification:** State breach notification laws apply with timelines varying from 30-72 hours depending on jurisdiction.
- **Annual Testing:** Tabletop exercise minimum annually. FINRA examiners will ask for the tabletop report and evidence of remediation of identified gaps.
- **Documentation:** Maintain a log of all cybersecurity incidents with date, nature, containment steps, root cause, and remediation.

4. Third-Party and Vendor Risk Under FINRA

FINRA holds member firms responsible for vendor cybersecurity failures:

- **Vendor Inventory:** Current inventory of all vendors with access to firm systems or customer data, tiered by risk level.
- **Due Diligence:** Security questionnaire and SOC 2 Type II for critical vendors before onboarding and annually thereafter.
- **Contractual Protections:** Data security requirements, incident notification within 24-48 hours, right to audit, and data handling on termination.
- **Cloud Vendors:** FINRA has issued specific guidance on cloud security. Require cloud security posture documentation and shared responsibility clarity.
- **Ongoing Oversight:** Annual vendor review cycle. FINRA examiners will ask how you monitor vendor security between contract renewals.

5. Remote Work and Mobile Security Under FINRA

FINRA has made remote work security a standing examination priority since 2020:

- **Remote Access Security:** All remote access through managed VPN with MFA. No unmanaged device access to firm systems.
- **Home Network Risk:** FINRA expects controls on the security of remote work environments including encrypted VPN, managed endpoint, and MFA at minimum.
- **Mobile Device Management:** MDM enrollment for all mobile devices accessing firm email, systems, or customer data. Remote wipe capability required.

- Electronic Communications: Remote workers must use firm-approved communications channels. Personal email and messaging apps for firm business violate recordkeeping rules.
- Supervision: Written supervisory procedures must specifically address how cybersecurity supervision is maintained for remote workers.

6. FINRA Cybersecurity Exam Readiness Checklist

Before a FINRA examination, confirm you can produce:

- Written cybersecurity policies and WSPs covering all cybersecurity activities
- Annual cybersecurity risk assessment with findings and remediation status
- Evidence of MFA deployment across all required systems
- BCP including cybersecurity incident response compliant with Rule 4370
- Tabletop exercise report from prior 12 months with gap remediation evidence
- Vendor inventory and due diligence files for critical vendors
- Incident log for prior 2-3 years
- Remote access and mobile device management documentation

NEXT STEP

Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

Book Your Assessment →

centience.ai/assessments/financial-services

Call us: (877) 945-7177